NORDWIND LOGISTICS GMBH

Richtlinie Incident Response und NIS-2-Meldeverfahren

Behandlung von Informationssicherheitsvorfällen und Erfüllung der Meldepflichten

Dok.-Nr.	NWL-ISMS-RL-009
Version	1.1
Stand	20.05.2025
Verantwortlich	Informationssicherheitsbeauftragter (ISB)
Freigabe	Geschäftsführung, 26.05.2025
Klassifizierung	INTERN

Inhaltsverzeichnis

1 Zweck und Geltungsbereich . . . 3

2 Begriffe . . . 3

2.1 Sicherheitsereignis (Event) . . . 3

2.2 Sicherheitsvorfall (Incident) . . . 3

2.3 Erheblicher Sicherheitsvorfall . . . 3

3 Rollen und Verantwortlichkeiten . . . 3

3.1 Incident Response Team (IRT) . . . 3

3.2 Weitere Beteiligte . . . 3

4 Meldung von Vorfällen (intern) . . . 3

5 Klassifizierung (Priorität P1–P4) . . . 4

6 Ablauf der Vorfallbehandlung . . . 4

6.1 Erkennung und Erstbewertung . . . 4

6.2 Eindämmung (Containment) . . . 4

6.3 Beseitigung und Wiederherstellung . . . 4

6.4 Lessons Learned . . . 4

7 Meldepflichten . . . 4

7.1 Bewertung und Entscheidung . . . 4

7.2 Fristen nach NIS-2 . . . 4

7.3 Meldestellen . . . 5

7.4 Datenschutzverletzungen (DSGVO) . . . 5

7.5 Information an den Konzern . . . 5

8 Dokumentation und Beweissicherung . . . 5

9 Übungen und Überprüfung . . . 5

1 Zweck und Geltungsbereich

Diese Richtlinie legt fest, wie Informationssicherheitsvorfälle bei der Nordwind Logistics GmbH gemeldet, bewertet, behandelt und dokumentiert werden und wie die Meldepflichten nach der NIS-2-Richtlinie (EU) 2022/2555 und den nationalen Umsetzungsgesetzen in Österreich, Deutschland und Tschechien erfüllt werden. Sie gilt für alle Standorte, alle Mitarbeitenden sowie für Dienstleister mit Zugang zu Nordwind-Systemen.

2 Begriffe

2.1 Sicherheitsereignis (Event)

Ein beobachtbares Ereignis mit möglicher Sicherheitsrelevanz, z. B. eine einzelne fehlgeschlagene Anmeldung oder ein Virenfund, der automatisch bereinigt wurde.

2.2 Sicherheitsvorfall (Incident)

Ein Ereignis, das die Vertraulichkeit, Integrität oder Verfügbarkeit von Informationen oder Systemen tatsächlich beeinträchtigt oder mit hoher Wahrscheinlichkeit beeinträchtigen wird, z. B. Malware-Infektion, Verlust eines Geräts mit Firmendaten, unbefugter Zugriff, Datenabfluss.

2.3 Erheblicher Sicherheitsvorfall

Ein Sicherheitsvorfall ist erheblich im Sinne von NIS-2, wenn er eine schwerwiegende Betriebsstörung der Dienste oder finanzielle Verluste für Nordwind verursacht hat oder verursachen kann oder wenn er andere natürliche oder juristische Personen durch erhebliche materielle oder immaterielle Schäden beeinträchtigt hat oder beeinträchtigen kann.

3 Rollen und Verantwortlichkeiten

3.1 Incident Response Team (IRT)

Das IRT steht unter der Leitung des ISB und besteht aus Vertretern des IT-Betriebs, der IT-Bereitschaft sowie – je nach Vorfall – den betroffenen Systemownern. Das IRT ist für Bewertung, Eindämmung, Beseitigung und Wiederherstellung zuständig.

3.2 Weitere Beteiligte

- **Geschäftsführung (GF):** Entscheidung über Meldungen an Behörden, Kommunikation nach außen, Freigabe außerordentlicher Maßnahmen
- **Datenschutzbeauftragte (DSB):** Bewertung von Datenschutzverletzungen, Meldung an die Datenschutzbehörde
- **Unternehmenskommunikation:** Abstimmung von Kunden- und Presseinformationen
- **Group Security Office:** Unterstützung bei P1-/P2-Vorfällen, Koordination konzernweit

4 Meldung von Vorfällen (intern)

Jede Mitarbeiterin und jeder Mitarbeiter, die oder der einen Sicherheitsvorfall bemerkt oder vermutet, meldet diesen **unverzüglich, spätestens jedoch innerhalb von 1 Stunde**, an den IT-Servicedesk (intern Durchwahl 4444, servicedesk@nordwind-logistics.example) oder an security@nordwind-logistics.example. Außerhalb der Servicezeiten (Mo–Fr 06:00–20:00 Uhr, Sa 06:00–14:00 Uhr) ist die IT-Bereitschaft unter +43 732 000 4400 erreichbar.

Fahrerinnen und Fahrer melden Vorfälle (z. B. Verlust oder Diebstahl eines Fahrzeug-Tablets) an die Disposition, die die Meldung umgehend an den Servicedesk weitergibt.

Bis zum Eintreffen des IRT gilt:

– Betroffenes Gerät nicht ausschalten, aber vom Netzwerk trennen (LAN-Kabel ziehen, WLAN deaktivieren).
– Keine eigenen Untersuchungen, keine Löschung von E-Mails oder Dateien.
– Beobachtungen (Uhrzeit, Meldungen am Bildschirm) notieren.

5 Klassifizierung (Priorität P1–P4)

Das IRT stuft jeden Vorfall bei der Erstbewertung in eine der folgenden Prioritäten ein. Die Einstufung kann im Verlauf angepasst werden.

Priorität	Beschreibung	Beispiele	Reaktionszeit IRT
P1 – kritisch	Ausfall oder Kompromittierung logistikkritischer Systeme mit Auswirkungen auf mehrere Standorte oder Kunden	Ransomware im Rechenzentrum; Ausfall des LVS an mehreren Standorten; Abfluss von Kunden- oder Sendungsdaten	15 Minuten, 24/7
P2 – hoch	Erhebliche Beeinträchtigung eines Standorts oder eines kritischen Systems	Kompromittiertes Administratorkonto; Ausfall des TMS; Malware auf einem Server	1 Stunde, 24/7
P3 – mittel	Begrenzte Auswirkungen auf einzelne Systeme oder Benutzer	Malware auf einem einzelnen Client; Verlust eines verschlüsselten Tablets	4 Stunden (innerhalb der Servicezeiten)
P4 – niedrig	Geringe Auswirkungen, kein Schaden erkennbar	Gemeldete Phishing-Mail ohne Klick; Richtlinienverstoß ohne Folgen	nächster Arbeitstag

6 Ablauf der Vorfallbehandlung

6.1 Erkennung und Erstbewertung

Der Servicedesk erfasst jede Meldung als Incident-Ticket der Kategorie „Security“ und informiert das IRT. Das IRT bewertet Art, Umfang und Priorität.

6.2 Eindämmung (Containment)

Betroffene Systeme werden isoliert, kompromittierte Konten gesperrt und Zugänge von Dienstleistern vorübergehend deaktiviert. Bei P1-Vorfällen kann der ISB die Trennung ganzer Standorte vom Firmennetz anordnen.

6.3 Beseitigung und Wiederherstellung

Die Wiederherstellung erfolgt aus geprüften, unveränderlichen Sicherungen gemäß den jeweiligen Notfallplänen. Nach einem Cyberangriff ist eine Wiederherstellung erst nach Freigabe durch den ISB zulässig.

6.4 Lessons Learned

Für P1- und P2-Vorfälle wird innerhalb von 10 Arbeitstagen nach Abschluss ein Lessons-Learned-Workshop durchgeführt. Die Maßnahmen werden in das ISMS-Maßnahmenregister aufgenommen.

7 Meldepflichten

7.1 Bewertung und Entscheidung

Der ISB bewertet gemeinsam mit dem IRT unverzüglich, ob ein erheblicher Sicherheitsvorfall im Sinne von Kap. 2.3 vorliegt. **Die Entscheidung über die Meldung an die zuständige Behörde trifft die Geschäftsführung auf Vorschlag des ISB.** Ist kein Mitglied der Geschäftsführung erreichbar, entscheidet der ISB allein, um die Fristen zu wahren, und informiert die Geschäftsführung nachträglich.

7.2 Fristen nach NIS-2

Meldung	Frist	Inhalt (Mindestangaben)	Verantwortlich
Frühwarnung	innerhalb von 24 Stunden nach Kenntnis des erheblichen Vorfalls	Verdacht auf rechtswidrige oder böswillige Handlung; mögliche grenzüberschreitende Auswirkungen	ISB
Vorfallmeldung	innerhalb von 72 Stunden nach Kenntnis	Aktualisierung der Frühwarnung; erste Bewertung (Schweregrad, Auswirkungen); Kompromittierungsindikatoren (IoC), soweit vorhanden	ISB
Zwischenbericht	auf Ersuchen der Behörde / des CSIRT	Relevante Statusaktualisierungen	ISB
Abschlussbericht	spätestens einen Monat nach Übermittlung der Vorfallmeldung	Ausführliche Beschreibung, Art der Bedrohung bzw. Ursache, ergriffene und laufende Abhilfemaßnahmen, ggf. grenzüberschreitende Auswirkungen	ISB mit IRT
Fortschrittsbericht	wenn der Vorfall zum Zeitpunkt des Abschlussberichts noch andauert; Abschlussbericht dann binnen eines Monats nach Abschluss der Behandlung	Stand der Behandlung	ISB

7.3 Meldestellen

Die Meldung erfolgt an das jeweils zuständige nationale CSIRT bzw. die zuständige Behörde des Landes, in dem der betroffene Standort liegt (Österreich, Deutschland, Tschechien). Bei Vorfällen mit Auswirkungen auf mehrere Länder koordiniert der ISB die Meldungen mit dem Group Security Office. Die aktuellen Kontaktdaten der Meldestellen (Meldeportale, Telefonnummern, Ansprechpartner) sind in Anhang B hinterlegt. Anhang B wird vom ISB separat gepflegt und ist nicht Bestandteil dieses Dokuments.

7.4 Datenschutzverletzungen (DSGVO)

Sind personenbezogene Daten betroffen (z. B. Empfängerdaten aus Sendungen), informiert der ISB unverzüglich die Datenschutzbeauftragte. Diese prüft eine Meldung an die zuständige Datenschutzbehörde binnen 72 Stunden (Art. 33 DSGVO). Die NIS-2-Meldung und die Meldung nach DSGVO sind getrennte Verfahren und ersetzen einander nicht.

7.5 Information an den Konzern

Bei Vorfällen der Priorität P1 und P2 ist das Group Security Office innerhalb von 12 Stunden zu informieren (gemäß Group Incident Reporting Standard). Dies gilt unabhängig davon, ob eine behördliche Meldepflicht besteht.

8 Dokumentation und Beweissicherung

Jeder Vorfall wird vollständig im Incident-Ticket dokumentiert (Zeitstempel, Maßnahmen, Entscheidungen). Beweismittel wie Logdateien, Speicherabbilder und Festplattenimages werden unverändert gesichert; die Weitergabe wird in einer Chain-of-Custody-Liste festgehalten. Die Vorfallsdokumentation wird 5 Jahre aufbewahrt.

9 Übungen und Überprüfung

Mindestens einmal jährlich wird eine Incident-Response-Übung (Tabletop) unter Beteiligung der Geschäftsführung durchgeführt. Diese Richtlinie wird jährlich sowie nach jedem P1-Vorfall überprüft.